Powerapps Progress Audit

What the developer's changes of 9 November improved, how the server has run since, what is still open, and two new findings that need action today.

Server **t3.small · 2 vCPU · 2 GB RAM + 1 GB swap** Measured **10 Nov 2026, 15:40 SAST** Follows **Follow-up Audit, 9 Nov 2026**

Summary

The code repository on GitHub is public and holds passwords and database backups

The repository the apps are deployed from (`Omega130920/Powerapps`) can be read by anyone on the internet. It holds the `.env` files with the database passwords and the Microsoft Graph client secret, nine database dumps including a 22 MB `full_server_backup.sql` , and 42 member documents. The Graph client secret gives access to the Outlook mailboxes the apps use. This is now the highest priority.

ACVV serves a database dump to anyone

`https://acvv.futurasa.co.za/crm_unity.sql` and `crm_unity_backup.sql` download without a login (HTTP 200). Each is a 5 MB MySQL dump with claims, notes, inbox and Outlook token tables. The nginx rule added on 9 November blocks source files but not `.sql` .

The memory work is paying off. Since the changes, swap use peaked at 66% (it reached 100% twice on 9 November), no process has been stopped for lack of memory, and the four main apps have logged one application error between them. The developer's code changes fixed most of the attachment memory problems in PSSUBF, Internal Unity and CRM Unity, and added timeouts to every Microsoft Graph call. ACVV's attachment handling has not changed yet, and the member documents found on 9 November can still be downloaded without a login.

TSRF and Consulting are offline. They are planned to go live in 2027, so this report does not cover them.

What the developer's changes fixed

Compared against the findings in the 6 and 9 November audits. The changes were committed on the evening of 9 November.

FINDING	APP	NOW
Opening an email loads every attachment into memory. Graph is now asked for names and sizes only (`$select`).	PSSUBF, Internal Unity	Fixed
Same, in CRM Unity. Names and sizes only, but image attachments are still fetched in full to show them inline.	CRM Unity	Mostly fixed
Attachment download holds the whole file in memory. PSSUBF now streams it from Graph in 8 KB pieces.	PSSUBF	Fixed
Same, in CRM Unity. It now uses Graph's `/$value` , which removes the base64 copy, but the file is still read whole before it is sent.	CRM Unity	Improved
Microsoft Graph calls have no timeout. All four apps now use a 5-second connect and 25- or 30-second read timeout.	All four	Fixed
Attachment fetch and download	ACVV	Not changed
Attachment download still decodes the whole file in memory	Internal Unity	Not changed

The token requests to Microsoft (`token_manager.py`) still have no timeout in any of the four apps. This is minor, as those calls are rare.

How the server has run since

MEASURE	9 NOVEMBER	10 NOVEMBER
Highest swap use	100% (twice)	66%
Processes stopped for lack of memory	MySQL, once	None
Memory available now	619 MB (after restarts)	376 MB
Swap in use now	680 MB	712 MB
Memory pressure (share of time stalled, 5 min)	–	0.2%

APP	STATUS	NOW	PEAK	LIMIT (SOFT / HARD)	ERRORS
PSSUBF	Running	205 MB	300 MB	300 / 400 MB	0
Internal Unity	Running	203 MB	269 MB	300 / 400 MB	0
CRM Unity	Running	184 MB	195 MB	450 / 550 MB	0
ACVV	Running	167 MB	197 MB	300 / 400 MB	1

“Peak” and “Errors” cover the time since each app restarted at about 21:04 SAST on 9 November. PSSUBF reached its 300 MB soft limit, where the system slows it down to reclaim memory, 232 times. Worker recycling replaced its workers four times. That suggests 300 MB is slightly tight for PSSUBF, though it never came near the hard limit. ACVV's single error was a claim save that failed because a company code was longer than its database column allows. TSRF and Consulting are offline until they go live in 2027.

New findings

CRITICAL **Public GitHub repository with secrets, database dumps and member documents**

GitHub reports the repository `Omega130920/Powerapps` as public. It was created on 29 September 2025 and last pushed at 21:02 SAST on 9 November. We checked through GitHub's public API, without logging in, that these files are in it:

- `.env` files for ACVV, CRM Unity and Internal Unity: Django secret key, database user and password, Microsoft Graph client ID, client secret and tenant ID
- The database password written into PSSUBF's `settings.py` (and Consulting's, in the repository history)
- Nine database dumps, among them `full_server_backup.sql` (22 MB), `crm_unity.sql` (68 MB), `pssubf_db_backup.sql` , `acvv_app_backup.sql` , `tsrf_recon_backup.sql` and `consulting_app_backup.sql` . They are stored as normal files, not in Git LFS.
- 42 member documents from ACVV, PSSUBF and Internal Unity upload folders

We did not download any of these files. GitHub shows no forks, but a public repository can be copied without leaving a trace, and automated tools scan GitHub for leaked secrets within minutes of a push.

Fix, in this order:

- Make the repository private today.
- Rotate the Microsoft Graph client secret in Azure, then change the database passwords and Django secret keys. Making the repository private does not undo the exposure, so this step is needed regardless.
- In Azure, check the sign-in logs of the app registration for use from unknown addresses.
- Remove `.env` , `*.sql` and all upload folders from the repository, add them to `.gitignore` , and clear them from the history (for example with `git filter-repo`).

POPIA: this exposure is wider than the one in the 9 November report, because the database dumps hold the members' records themselves, not only uploaded documents. The client's Information Officer should include it in the review that is already open.

`All apps` `GitHub`

CRITICAL **ACVV serves a database dump**

The ACVV project folder holds `crm_unity.sql` and `crm_unity_backup.sql` , two copies of a 5 MB MySQL dump with Internal Unity tables (claims, notes, inbox, delegations, Outlook tokens). Because ACVV serves its whole project folder (`MEDIA_ROOT = BASE_DIR`), both download without a login. It has been in the folder, and in the repository, since June 2026.

Fix: the server administrator can block it today by adding `sql` , `gz` and `zip` to the nginx rule added on 9 November. The developer should then delete the two files from the server, as they have no reason to be in the project folder. The lasting fix is the one already planned: stop using `MEDIA_ROOT = BASE_DIR` .

`ACVV`

Still open

FINDING	APPS	STATUS
Member documents download without a login (still HTTP 200). Files now: ACVV 605, PSSUBF 629, Internal Unity 2,292.	ACVV, PSSUBF, Internal Unity	Open
ACVV serves its project folder (`MEDIA_ROOT = BASE_DIR`). Source and `.env` are blocked in nginx, the database dump is not.	ACVV	Open
Change the secrets in `.env` . This is now urgent, see the GitHub finding.	All	Open
Debug mode on. CRM Unity was due to be turned off this morning, and it is still on.	All four	Open
Attachment fetch and download in memory	ACVV, Internal Unity download	Open
MySQL memory protection is set but not active. MySQL has not been restarted.	MySQL	Waiting on restart
Database login as `root` , password in `settings.py`	PSSUBF	Open
Python 3.9 and Django 4.2 out of support	All	Open

Action plan

ACTION	OWNER	WHEN
Make the GitHub repository private	Developer	Immediately
Rotate the Graph client secret, database passwords and Django secret keys; check Azure sign-in logs	Developer Client	Immediately
Block `.sql` , `.gz` and `.zip` in ACVV's nginx rule	Server admin	Immediately
Delete the two SQL dumps from the ACVV folder	Developer	Today
Add the GitHub exposure to the POPIA review	Client	Today
Turn CRM Unity debug mode off	Server admin	Today
Remove secrets, dumps and uploads from the repository and its history	Developer	This week
Remove public media serving; serve ACVV files through a login-protected view	Developer	This week
Fix ACVV attachment handling and Internal Unity's download	Developer	This week

ACTION	OWNER	WHEN
Restart MySQL at a quiet time	Server admin	Quiet time, this week
Raise PSSUBF's memory limit to 350 / 450 MB	Server admin	This week
Turn debug mode off in all apps (after the media fix)	Developer	After media fix
Dedicated database user for PSSUBF	Developer	Next 2 weeks
Decide on the server upgrade	Client	Next 2 weeks

Server upgrade costs

Prices repeated from the earlier audits; the recommendation has changed. On 9 November we recommended a t3.large until the attachment handling was fixed. PSSUBF, Internal Unity and CRM Unity no longer load every attachment, so the remaining risk is mainly ACVV, and a t3.medium is now enough. It doubles the memory and leaves room for the apps to grow.

INSTANCE	VCPU	RAM	USD / HOUR	USD / MONTH*	CHANGE VS. NOW
t3.small current	2	2 GB	$0.0271	≈ $19.78	–
t3.medium RECOMMENDED	2	4 GB	$0.0542	≈ $39.57	+ $19.79
t3.large	2	8 GB	$0.1084	≈ $79.13	+ $59.35

*On-demand pricing for the AWS Cape Town region (af-south-1), Linux, 730 hours a month, in US dollars excluding VAT. Covers the server only. A 1-year AWS Savings Plan typically lowers these rates by about 30–40%. Prices are indicative and should be confirmed against current AWS pricing before ordering.

Sources: the deployment's Git history and the apps' source code; live process, memory and systemd figures and sysstat records for 9–10 Nov 2026; service logs; HEAD requests without a login against the public sites; GitHub's public API.

The checks in this report only read files, logs and web responses. No member files or database dumps were downloaded, and nothing on the server was changed.